



IT Service Security

Spring 2026

Time:

Friday: 9:00am – 12:00pm

Instructor: Soumya Ray

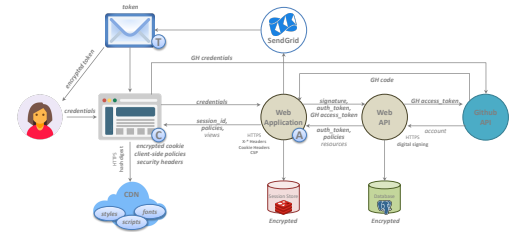
soumya.ray@iss.nthu.edu.tw

TA: 何捷睿 Jerry Ho

(only contact on MS Teams)

Companies, government, and educational institutions are rushing to deliver online services and incorporate AI. Security is a major concern in these initiatives because bad actors are quickly exploiting weaknesses. Secure IT services *protect the privacy* of users and can even be a *competitive advantage* when offered as a core feature.

This course will teach how to *develop highly secure online services* and lead organizations to adopt a *security-conscious culture*. This class focuses on the use of *cryptographic technologies* and *software architecture patterns* to create innovative online services for e-commerce, fintech, IoT, and other hi-tech initiatives.



Prerequisites: *This course is intended for students who are already be comfortable with programming:*

- Coding in an object-oriented language (Java, Javascript, C#, C++, Python, PHP, Ruby, etc.)
- Basic web page design (HTML, CSS)
- Basic database design (relational design, ERD/SQL)
- Unix based systems (Linux, MacOS, etc.)

Objectives: This course will enable students to design better security practices, develop secure software, interact with security practitioners, and digest the latest technical developments about security. You will also be able to help your future organizations to manage and implement secure solutions.

Ethics Statement on Generative Artificial Intelligence: *In accordance with the published Guidelines for Collaboration, Co-learning, and Cultivation of Artificial Intelligence Competencies in University Education, this course adopts the following policy: **unrestricted use***

Grading: Grades are based mainly on individual performance: class/online participation; individual assignments; and contributions to the team project. Students will work as a team on a semester project to develop an innovative online security system. However, students on a team do not receive the same grade for the team project: each student is evaluated on their individual coding contribution to the project.

Class and Online Participation: 10%

Individual Homeworks: 20%

Project Contribution: 70%

Course Topics

(tentative—subject to change)

Introduction to Information Theory

1. **Service Security:**

Services & Security
Meet Your Tools

Linux Tutorial 1
Ruby Tutorial 1
CODE: Setup Linux & Ruby

2. **Information Theory**

Information Entropy
Binary Numbers
Binary Operations

Linux Tutorial 2
Ruby Tutorial 2
CODE: XOR Defender

Cryptography: applying cryptographic principles

3. **Data Encoding and Error**

Testing
Information Encoding (UTF-8)
Error checking

Linux Tutorial 3
Ruby Tutorial 3
CODE: Credit Card Example - Luhn

4. **Cryptography Beginnings**

Serializing versus Marshalling Data
Simple Symmetric-Key Crypto
Modern Perspectives

Git Tutorials 1
CODE: Credit Card Example - Crypto

5. **Symmetric Key Cryptography**

Stream & Block Ciphers
Brittleness/Complexity of SK Crypto
Cryptographic Hashing

Git Tutorials 2
CODE: Credit Card Example - Ciphers
READING: Block-chain and Fintech

6. **Public Key Cryptography**

Asymmetric Cryptography
Complexity Theory
Generating Public/Private Keypairs

PROPOSALS: Team Projects

Web Services: secure storage

7. **Web Security**

PK Crypto & Web-of-Trust
Internet Infrastructure
Web Services

8. **Databases and Web Testing**

Environments & Utilities
Simple Databases: Sqlite
Web Testing

9. Database Hardening

- Threat Model and Matrix
- Database Vulnerabilities
- Securing Database Columns

Users: Accounts and Authentication

10. User Accounts

- Protecting Passwords
- Account Infrastructure
- Cloud Deployment

11. Interface and Authentication

- API Deployment
- Interface Client
- Cookies, TLS/SSL

12. Secure Sessions

- Hardened Cookies and Sessions
- Secure Messaging
- Account Registration

Security Policy: Authorization and Validation

13. Token-based Authorization

- JWT controversy
- Discretionary Access Control
- Authorization Tokens

14. Policies and Validation

- Distributed Security Policy
- Policy Objects
- Form Validation

15. Authorization Protocols

- OAuth Flow
- Distributed OAuth
- Single-Table Inheritance

16. Client-Side Security

- Authenticating API Clients
- XSS / CSRF
- Browser Defense: Headers, CSP, Integrity

17. Final Team Presentations